

PLAN DE RESPUESTA A INCIDENTE DE RANSOMWARE

Basado en el Marco de Ciberseguridad NIST

Organización:	TechCo — Servicios en la Nube
Clasificación:	Confidencial — Uso Interno
Marco de referencia:	NIST Cybersecurity Framework (CSF)
Versión:	1.0
Fecha:	08-06-2026
Áreas cubiertas:	Identificación, Protección, Detección, Respuesta, Recuperación

Resumen Ejecutivo

TechCo sufrió un ataque de ransomware originado por un correo de phishing que permitió a los atacantes cifrar servidores críticos, la base de datos de clientes y los sistemas de backup. El presente documento establece un plan formal de respuesta alineado con las cinco funciones del NIST CSF: Identificar, Proteger, Detectar, Responder y Recuperar; con el objetivo de contener el impacto actual y prevenir incidentes futuros.

1. Identificación (Identify)

Evaluar los activos críticos afectados, las vulnerabilidades explotadas y el contexto organizacional del incidente.

1.1 Activos Críticos Afectados

Activo	Impacto
Servidor de Archivos	Cifrado completo; documentos e información operativa inaccesibles.
Base de Datos de Clientes	Datos personales y financieros comprometidos y cifrados.

Sistemas de Backup Internos	Cifrados junto a producción; imposible restauración sin clave.
Red Interna (LAN)	Sin segmentación; vector de propagación del ransomware.
Estación del empleado afectado	Punto de entrada inicial por phishing.

1.2 Vulnerabilidades Identificadas

- Ausencia de filtros antiphishing y antimalware en el correo corporativo.
- Falta de segmentación de red (backups en el mismo segmento que producción).
- Sin monitoreo en tiempo real ni sistema de detección de intrusiones (IDS/IPS).
- Backups no aislados del entorno productivo (estrategia 3-2-1 no implementada).
- Capacitación insuficiente del personal en reconocimiento de amenazas de ingeniería social.

2. Protección (Protect)

Controles y políticas que TechCo debe implementar para reducir la probabilidad y el impacto de futuros ataques.

2.1 Controles Técnicos

Control	Descripción
Segmentación de Red (VLAN)	Separar backups, producción, administración y usuarios en segmentos aislados.
Regla de Backup 3-2-1	3 copias, 2 medios distintos, 1 offsite o en la nube (air-gapped).
EDR en todos los endpoints	Implementar Endpoint Detection & Response con análisis de comportamiento.
Filtro antiphishing / antimalware	Solución de seguridad de correo (ej. Microsoft Defender for O365, Proofpoint).
MFA obligatorio	Autenticación multifactor para todos los accesos a sistemas críticos.
Principio de mínimo privilegio	Restringir permisos de usuarios a lo estrictamente necesario.

2.2 Controles Organizacionales

- Política de gestión de parches: aplicar actualizaciones críticas en menos de 72 horas.
- Política de uso aceptable de equipos y correo electrónico.
- Programa de capacitación continua en ciberseguridad (phishing simulado, concientización).
- Plan de continuidad del negocio (BCP) y pruebas semestrales de recuperación ante desastres.

3. Detección (Detect)

Herramientas, procesos y alertas para identificar un ataque de ransomware en sus fases más tempranas.

3.1 Herramientas Recomendadas

Herramienta / Sistema	Función
SIEM (ej. Splunk, Microsoft Sentinel)	Correlación de eventos, alertas en tiempo real y análisis de logs centralizado.
IDS/IPS (ej. Snort, Suricata)	Detección y bloqueo de tráfico malicioso en la red.
EDR (ej. CrowdStrike, SentinelOne)	Detección de comportamientos anómalos en endpoints (cifrado masivo, movimiento lateral).
Monitoreo de integridad de archivos (FIM)	Alertar ante cambios masivos o inusuales en sistemas de archivos.
Honeypots	Señuelos para detectar movimiento lateral antes de que alcance activos reales.

3.2 Indicadores de Compromiso (IoC) a Monitorear

- Actividad masiva de escritura o cambio de extensiones de archivos.
- Procesos desconocidos con alto uso de CPU o intentos de escalar privilegios.
- Conexiones salientes a dominios/IPs no reconocidos (posible C2 - Command & Control).
- Intentos de deshabilitar servicios de backup o shadow copies.
- Correos con adjuntos ejecutables o macros desde remitentes desconocidos.

4. Respuesta (Respond)

Plan de acción inmediato ante la detección o confirmación de un ataque de ransomware activo.

4.1 Equipo de Respuesta a Incidentes (ERI)

Rol	Responsabilidades
Líder de Incidente (CISO / IT Manager)	Coordina todas las acciones, toma decisiones críticas, aprueba comunicaciones.
Equipo Técnico (IT / Seguridad)	Aísla sistemas, analiza el malware, aplica parches y restaura servicios.
Asesor Legal	Evalúa obligaciones legales (notificación a reguladores, GDPR/protección de datos).

Comunicaciones / RRHH	Gestiona comunicación interna con empleados y mensajes externos.
Relaciones con Clientes	Notifica a clientes afectados conforme a los requisitos legales.

4.2 Fases de Respuesta

• FASE 1 — Contención (0–2 horas)

1. Aislar inmediatamente todos los sistemas afectados de la red (desconectar de LAN/WiFi).
2. Deshabilitar cuentas de usuario comprometidas y revocar accesos VPN.
3. Preservar imágenes forenses de los sistemas afectados antes de cualquier remediación.
4. Notificar al Equipo de Respuesta a Incidentes y activar el plan de contingencia.

• FASE 2 — Análisis y Erradicación (2–24 horas)

5. Identificar la cepa del ransomware y buscar herramientas de descifrado en nomoreransom.org.
6. Determinar el vector de entrada y cerrar la brecha de seguridad.
7. Eliminar el malware de todos los sistemas y verificar limpieza completa.
8. Evaluar el alcance total de la filtración de datos para cumplimiento legal.

4.3 Política de Pago de Rescate

TechCo NO pagará el rescate como política predeterminada. El pago no garantiza la recuperación de datos, puede financiar actividades delictivas y expone a la empresa a sanciones legales. Se consultará a las autoridades (PDI, CSIRT de Gobierno de Chile) antes de cualquier decisión diferente.

4.4 Comunicación

- Interna: Notificar a la alta gerencia en las primeras 2 horas; actualizaciones cada 4 horas al equipo directivo.
- Clientes afectados: Notificación formal dentro de las 72 horas, según la Ley 19.628 (protección de datos personales en Chile).
- Autoridades: Reportar a CSIRT de Chile (csirt.gob.cl) y a la PDI si corresponde.
- Proveedores / terceros: Informar a partners y proveedores de nube que puedan verse afectados.

5. Recuperación (Recover)

Pasos para restaurar las operaciones normales de TechCo y garantizar la continuidad del negocio.

5.1 Restauración de Sistemas

Fase	Acciones
Validación de backups	Verificar la integridad de backups offsite/cloud antes de restaurar. Confirmar que estén libres de malware.
Restauración prioritaria	Recuperar primero los sistemas críticos: BD clientes, servidor de archivos, email corporativo.
Reimagen de equipos	Formatear y reinstalar sistemas operativos en equipos comprometidos; no restaurar desde snapshots infectados.
Pruebas funcionales	Validar cada sistema restaurado antes de reconectarlo a la red de producción.
Vuelta a operación normal	Reintegrar progresivamente servicios, monitoreando activamente por posibles reinfecciones.

5.2 Plan de Continuidad del Negocio (BCP)

- Activar entornos de contingencia (sistemas en la nube o sitio alternativo) para mantener operaciones críticas.
- Utilizar comunicación alternativa (correo personal, teléfono) mientras los sistemas corporativos están comprometidos.
- Establecer un periodo objetivo de recuperación (RTO) de máximo 48 horas para sistemas críticos.
- Definir un punto objetivo de recuperación (RPO) de máximo 24 horas de pérdida de datos aceptable.

6. Mejora Continua

Proceso para evaluar la efectividad del plan tras el incidente e integrar las lecciones aprendidas.

6.1 Revisión Post-Incidente (RPI)

- Realizar una reunión de lecciones aprendidas dentro de los 5 días posteriores a la resolución.
- Documentar: qué ocurrió, cómo fue detectado, qué tardó la respuesta, qué falló y qué funcionó.
- Generar un informe formal con hallazgos y recomendaciones priorizadas.

6.2 Métricas de Efectividad del Plan

Métrica	Objetivo
Tiempo de detección (MTTD)	< 1 hora desde inicio del ataque.
Tiempo de contención (MTTC)	< 2 horas desde la detección.

Tiempo de recuperación (MTTR)	< 48 horas para sistemas críticos.
Empleados capacitados en phishing	> 90% del personal al año.
Pruebas de restauración de backup	Al menos 2 veces al año con resultado exitoso.

6.3 Actualización del Plan

- Revisar y actualizar este plan al menos una vez al año o tras cualquier incidente significativo.
- Incorporar nuevas amenazas y tácticas identificadas en informes de inteligencia (CISA, CSIRT Chile).
- Realizar simulacros (tabletop exercises) semestrales para entrenar al equipo de respuesta.

Conclusión

El ataque de ransomware sufrido por TechCo expuso vulnerabilidades críticas en su infraestructura, procesos y cultura de seguridad. La implementación de este plan basado en el NIST CSF permitirá a la organización no solo responder efectivamente ante futuros incidentes, sino también fortalecer su postura de seguridad de forma integral. El compromiso de la alta gerencia, la capacitación continua del personal y la mejora iterativa del plan son los pilares fundamentales para una ciberseguridad resiliente.